AI security review that never sees the cloud.

Cloud AI code review means uploading your proprietary source to someone else's servers. For regulated, air-gapped, or simply confidential codebases, that's a **non-starter**.

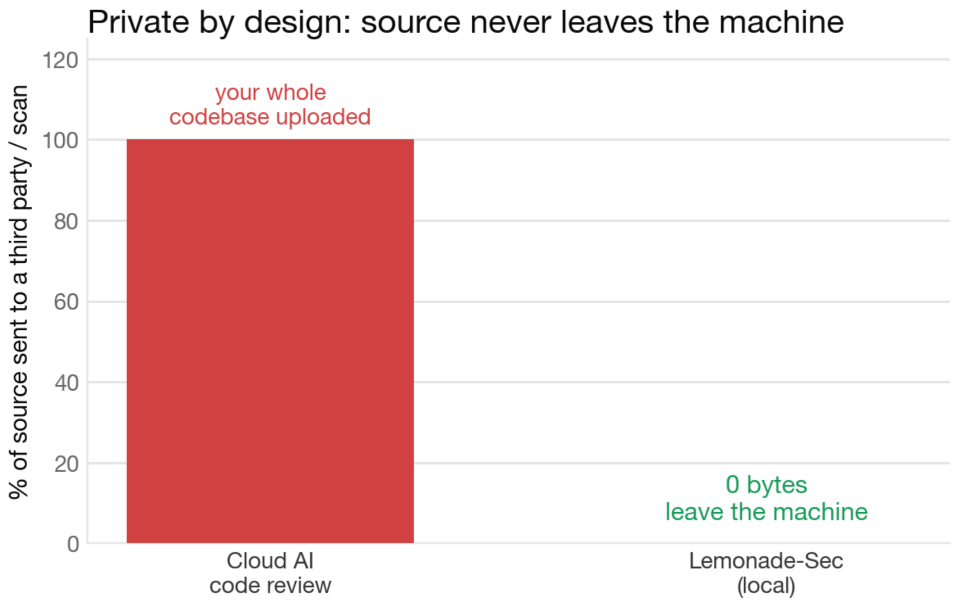
Lemonade-Sec runs the **entire** pipeline — static analysis *and* AI reasoning — **locally, on your own machine**, powered by AMD Lemonade.

0
BYTES LEAVE THE BOX

35
RULES · WEB2 + WEB3

$0
MIT CORE · NO KEYS

ARCHITECTURAL FACT · WHERE YOUR CODE GOES



PRODUCT · WHAT IT DOES MEASURED

Scan → local-AI triage → report, in one command.

The pipeline

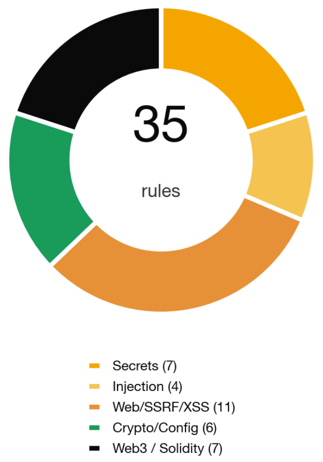
- **SAST core** — 35 regex rules across secrets, injection, SSRF, XSS, crypto, JWT + **web3/Solidity** (reentrancy, arbitrary `delegatecall`…).
- **Local AI triage** — each finding + code context + attack playbook → your **Lemonade** model returns verdict, confidence, and a PoC idea.
- **OpenAI-compatible** — auto-discovers the model via `/models`; works with any local server.
- **Graceful offline fallback** — no server? A built-in heuristic still produces a report. Never a network call you didn't ask for.

0
PIP DEPENDENCIES

14
FINDINGS ON DEMO

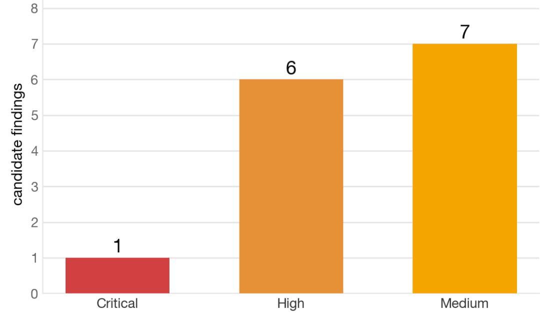
1 cmd
TO RUN

Coverage across web2 + web3 in one pass



MEASURED · `python3 lemonade_sec.py samples --triage`

14 findings on the demo sample, each AI-triaged locally



Stdlib-only · authorized-use gate (`--scope`) · findings are candidates

Two waves collide: local AI + AI-native AppSec.

Who pays — and can't use cloud AI

- Banks & fintech (source-code residency rules)
- Defense, gov, critical infrastructure (air-gapped)
- Healthcare & anyone under strict IP/NDA
- Enterprises banning code in public chatbots

Why now

- On-device LLMs went usable: **Lemonade 2.7k★**, AMD Strix Halo / Ryzen AI, 128 GB unified memory.
- AppSec is shifting to AI triage — but privacy blocks cloud adoption.

Market sizing (modeled, directional)

TAM · APPSEC / SAST + AI CODE TOOLS

≈ $6–8B

2026, growing double-digits

SAM · PRIVACY-CONSTRAINED / ON-PREM-REQUIRED ORGS

≈ $0.9B

regulated + air-gapped segment

SOM · 3-YR OBTAINABLE (OPEN-CORE WEDGE)

≈ $15–25M

land free → expand to paid teams

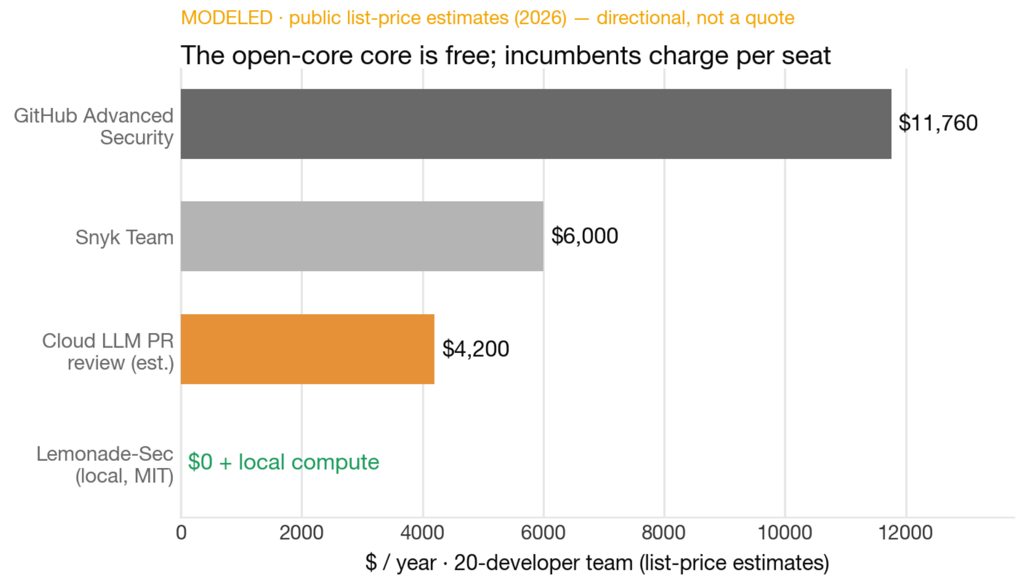
Figures are modeled from public market estimates — directional sizing, not audited.

Free core drives adoption; teams pay for the enterprise layer.

TIER	PRICE (MODELED)	WHAT'S IN IT
Core MIT	**$0**	CLI, 35 rules, local Lemonade triage, offline fallback
Team	**$15** /dev/mo	SARIF + CI gates, policy-as-code, baseline/diff, dashboards
Enterprise	**$40** /dev/mo	SSO/RBAC, audit, air-gap deploy, managed local-model ops, support/SLA

Unit economics (illustrative)

- Land free (OSS) → expand to Team → Enterprise. **NRR>120%** target via seat growth.
- Near-zero COGS: inference runs on the **customer's** hardware, not ours.
- 200-dev enterprise ≈ **$96k ARR**; 30 such logos ≈ **$2.9M ARR**.



Incumbents charge per seat and require the cloud. Our core is free and local; we monetize CI/governance/support — not the scan.

Built, tested, and riding the AMD local-AI wave.

Traction today REAL

- Working tool: scans + local-AI triage, **14 findings** on the demo, MIT on GitHub.
- **Measured on AMD Instinct MI300X** (torch-ROCm, fp16): **62–64 tok/s** decode (1.5B & 7B) · **19–21 ms** TTFT — triage runs on real AMD silicon, GPU far from saturated (room to grow with vLLM).
- Submitted to the **AMD Lemonade Developer Challenge**; author is an **AMD ACT I winner · Developer Featured** — warm ecosystem channel.

Roadmap

- SARIF + GitHub code-scanning · AST taint-tracking to cut false positives
- Ship as a Lemonade Marketplace app · design-partner pilots

Valuation frame (illustrative · pre-revenue)

Comparables in AI-native AppSec: **Semgrep**, **Snyk**, **Socket** — venture-backed on OSS-led adoption.

MODELED EARLY-STAGE RANGE

$3–6M

pre-seed, on team + wedge + AMD tailwind — a frame, not a quote

The ask

Design partners in regulated eng orgs · a Lemonade marketplace slot · and the AMD hardware/relationship to make local-AI AppSec the default.